



SMART-CONTRACT SECURITY ASSESSMENT

AEGENT V2 Smart-Contract Assurance Matrix

Assurance Matrix / Evidence-Oriented Profile

Author and issuer: AEGENT Security Review Team

Assessment date: 2026-07-29

Target environment: BNB Chain mainnet deployment candidate

Assessment type: Point-in-time source review

FINAL DISPOSITION remediation required before mainnet

This is an AEGENT-authored first-party security assessment. It was not authored, reviewed, endorsed, certified, signed, or issued by OpenZeppelin, CertiK, SlowMist, or any other independent auditor. It contains no third-party logo, signature, certificate, report number, or issuance claim. Its control-matrix presentation is a project-owned format for technical review and remediation tracking.

Contents

1. Assurance result

2. Scope identity

3. Architecture and asset map

Principal roles

4. Control assurance matrix

5. Accepted findings

MED-01 — Manual-review threshold can be bypassed by splitting redemptions

MED-02 — Purchases can increase refund liability without enforced reserve collateral

MED-03 — Freshness-only oracle validation lacks bounds and deviation circuit breakers

LOW-01 — Fixed UTC daily buckets permit near-two-times throughput at a boundary

INFO-01 — Privileged controls do not enforce a multisig or general timelock

INFO-02 — Immutable recipients and narrow recovery paths create asset-liveness risk

INFO-03 — Settlement events omit configuration evidence needed for complete reconstruction

6. Verification matrix

Toolchain

Dynamic tests

Coverage

Static analysis

7. Mainnet remediation gates

8. Limitations

9. Conclusion

1. Assurance result

The assessed snapshot implements substantial controls around phase and mode binding, slippage and deadline protection, reentrancy resistance, token balance reconciliation, purchase-cost accounting, claim clearing, redemption replay protection, and liability-preserving withdrawals.

No Critical or High-severity issue was identified. The assessment nevertheless found three open Medium issues that prevent a positive mainnet recommendation:

1. manual-review policy is evaluated per transaction and can be bypassed by splitting;
2. purchases can create refund liabilities without an enforced reserve-collateral invariant;
3. oracle validation checks freshness but not economic bounds, heartbeat-specific age, or price deviation.

Severity	Open	Closed
Critical	0	0
High	0	0
Medium	3	0
Low	1	0
Informational	3	0

All seven accepted findings are **Open; no remediation retest**. Tool alerts that were rejected during manual triage are not included in this accepted finding count.

2. Scope identity

The controlling audit source is the frozen copy under [source-snapshot/](#). Repository commit [cae20adb0497c46906e36cb98bcd3d19232c98b](#) is retained only as workspace context and is not represented as containing the uncommitted snapshot.

Frozen source	SHA-256
contracts/AagentMarketRegistry.sol	1e0fc93396402b19d085bbfc25d03be53540e847039dd768c6d47bf379f49aa9
contracts/AagentSaleProceedsVault.sol	983af93be4bb1fcbe2809c9fb01baea34a7bae0ddf12caf05933c5450842cc34
contracts/AagentSwapV2.sol	2b53552a367b757cc31721d31cb2e889dc9391afc293a4cac0b2590332fb515f
contracts/AagentRedemptionV2.sol	2424be9e3141b055d0a27a7b12ab6fc3918d758ddbedc9201ebc454dd467fcc6
contracts/interfaces/IAagentMarketRegistry.sol	fb7b9a35bef353c3c0a5e882da595294b9dadb8d81cedada1207bbfe7bb02309
contracts/interfaces/IAagentPurchaseReceiptSource.sol	52abd846c87734040bfb375177186bff6d8b56f9b23ddbeeb8a7a4f4c3d5badb

Frozen source	SHA-256
contracts/interfaces/IAgentRedemptionEndpoint.sol	92620d9cc1fec26c42b4d4d293447d4faf9d83aab05a065d7484eff299d89eab
contracts/interfaces/IAgentRegistryBound.sol	bf53c7606cbc5853a74710c9fa31dfd256a31283eedaf7ede01e213b0f12bc84
contracts/interfaces/IAgentSaleProceedsVault.sol	eb1005d38941efc7dfd9e8c961eb5a4df10f9a43f630330495dd82b73854c974
contracts/interfaces/IAggregatorV3.sol	2dc0d69856b9cf3579d866c1da3bb9baff2fe505d9702001fcddc47e319a2b7e

Out of scope:

- mocks except as test evidence;
- deployment scripts except their local safety tests;
- frontends, APIs, database finality ledgers, wallet integrations, and operational monitoring;
- deployed bytecode, constructor arguments, proxy state, ownership addresses, multisig configuration, timelock configuration, reserve balances, oracle-address registry, and mainnet receipts;
- private keys, signing procedures, incident response, and production access control.

3. Architecture and asset map

Component	Primary responsibility	Assets or authority
AagentMarketRegistry	Authoritative sale schedule, phase, market mode, limited windows, endpoints, and configuration version	Market-state authority
AagentSaleProceedsVault	Hold native BNB and supported stablecoin sale proceeds until <code>saleEnd</code>	BNB, USDT, USDC sale proceeds
AagentSwapV2	Quote and settle BNB/USDT/USDC purchases, transfer AGNT, record purchase receipts, and forward proceeds	AGNT inventory, purchase accounting, oracle-derived pricing
AagentRedemptionV2	Presale cost-basis refunds, post-launch redemption, purchased-AGNT claims, reserve accounting, limits, and execution nonces	USDT redemption reserve, escrowed AGNT, refund liabilities

Principal roles

Role	Capability	Required assumption
Owner	Configure market state, propose/apply rates, pause flows, and withdraw eligible balances	Owner is secure, honest, monitored, and preferably a multisig
Buyer / redeemer	Submit bounded purchase or redemption parameters	User supplies meaningful minimum output and correct network/address

Role	Capability	Required assumption
Oracle	Provide BNB and stablecoin prices	Feed is official, live, economically representative, and correctly configured
Vault beneficiary	Receive released sale proceeds	Address remains available and accepts native BNB
AGNT / USDT / USDC token contracts	Execute ERC-20 transfers	Tokens conform to the behavior assumed by balance-delta checks
Off-chain indexer / API	Reconstruct events and present executable calldata	Does not weaken contract-side checks and validates expected configuration

4. Control assurance matrix

Ratings:

- **Satisfied:** implemented in the reviewed snapshot with direct code and test support.
- **Partially satisfied:** useful control exists, but an accepted weakness remains.
- **Not satisfied:** the expected control is absent or does not enforce the stated objective.
- **Operational evidence required:** the source supports the control, but deployment configuration was not supplied.

Control ID	Objective	Implementation evidence	Assessment
GOV-01	Prevent accidental ownership loss	Two-step ownership is used; renunciation is disabled	Satisfied in source
GOV-02	Reduce unilateral privileged-action risk	Some rate changes have a one-day proposal delay	Partially satisfied — INFO-01
GOV-03	Enforce multisig and general timelock	No on-chain requirement that owner be a multisig or that general changes be timelocked	Not satisfied — INFO-01
CFG-01	Bind endpoints to one authoritative Registry	Registry address and endpoint compatibility are checked	Satisfied in source
CFG-02	Prevent stale configuration replay	Purchases and redemptions compare expected configuration version	Satisfied in source
CFG-03	Bind execution to expected phase and mode	Both flows compare expected phase and market mode	Satisfied in source
PUR-01	Restrict purchases to the valid sale window	Registry schedule, active phase, market mode, and optional limited window are checked	Satisfied in source
PUR-02	Limit price movement and transaction lifetime	Minimum AGNT output and a maximum five-minute deadline are enforced	Satisfied in source
PUR-03	Prevent accounting against fee-on-transfer behavior	Stablecoin and AGNT balance deltas are checked around transfers	Satisfied in source

Control ID	Objective	Implementation evidence	Assessment
PUR-04	Prevent purchase-created refund undercollateralization	Purchase admission does not check projected redemption reserve coverage	Not satisfied — MED-02
ORC-01	Reject missing, negative, future, incomplete, or stale oracle data	Answer, timestamp, round ordering, and global max age are checked	Satisfied in source
ORC-02	Reject economically implausible but technically fresh prices	No absolute bound, per-feed heartbeat, deviation limit, secondary source, or circuit breaker	Not satisfied — MED-03
CUST-01	Prevent reentrant purchase/redemption settlement	State-changing settlement paths use <code>nonReentrant</code>	Satisfied in source
CUST-02	Use hardened ERC-20 interactions	<code>SafeERC20</code> and balance reconciliation are used	Satisfied in source
CUST-03	Preserve outstanding liabilities during withdrawals	Withdrawal availability accounts for presale liabilities and unclaimed AGNT	Satisfied in source
CUST-04	Recover accidentally forced or unrelated assets safely	Recovery is intentionally narrow; immutable recipients can create liveness failure	Partially satisfied — INFO-02
RED-01	Prevent presale refunds above wallet entitlement	Cost basis and remaining entitlement are wallet-specific and decremented	Satisfied in source
RED-02	Prevent post-launch redemption without AGNT	Post-launch flow collects AGNT and reconciles balance deltas	Satisfied in source
RED-03	Prevent calldata replay	Per-wallet <code>nextRedemptionNonce</code> is included and consumed atomically	Satisfied in source
RED-04	Preserve minimum output and bounded execution time	Minimum USDT output and deadline checks are enforced	Satisfied in source
RISK-01	Enforce wallet/global daily limits	Per-wallet and global totals are enforced per UTC day index	Partially satisfied — LOW-01
RISK-02	Force review above a risk threshold	Current transaction gross amount is compared to the threshold	Partially satisfied — MED-01
RISK-03	Prevent splitting around the review threshold	No cumulative threshold or signed reviewed path exists	Not satisfied — MED-01
EVT-01	Make purchase settlement independently reconstructable	Event records settlement amounts and identifiers	Partially satisfied — INFO-03
EVT-02	Make redemption settlement independently reconstructable	Event includes mode and execution nonce	Partially satisfied — INFO-03
DEP-01	Prove reviewed source equals deployed bytecode and constructor parameters	No deployed address or verification record was supplied	Operational evidence required

Control ID	Objective	Implementation evidence	Assessment
DEP-02	Prove correct owner, multisig, oracle, token, vault, reserve, and endpoint configuration	Deployment state was not supplied	Operational evidence required

5. Accepted findings

MED-01 — Manual-review threshold can be bypassed by splitting redemptions

Status: Open; no remediation retest

Code: [`AagentRedemptionV2.sol:L190-L227`](#), [`AagentRedemptionV2.sol:L694-L731`](#)

Test: [`AagentRedemptionV2.test.cjs:L454-L494`](#)

The constructor permits `manualReviewThresholdUsdt <= dailyWalletUsdtLimit`. `_validateRedemption` compares only the current transaction's `grossUsdt` with the manual-review threshold, while the wallet total is checked separately against the daily limit.

The regression test proves that one 201-USDT-equivalent redemption is rejected, but two 200-USDT-equivalent redemptions succeed; only a third transaction encounters the 400-USDT daily-wallet cap.

Impact: A redeemer can process the full wallet/global daily allowance without entering the intended review path, provided each transaction remains at or below the threshold. Entitlement, reserve, AGNT-transfer, and daily-cap checks still apply.

Required remediation: Evaluate the review requirement against cumulative wallet activity in a rolling or daily interval, or add a reviewer-authorized execution path bound to wallet, maximum amount, nonce, and expiry. Add split-transaction negative tests.

MED-02 — Purchases can increase refund liability without enforced reserve collateral

Status: Open; no remediation retest

Code: [`AagentMarketRegistry.sol:L186-L227`](#), [`AagentSwapV2.sol:L249-L289`](#), [`AagentSwapV2.sol:L358-L380`](#), [`AagentRedemptionV2.sol:L522-L553`](#), [`AagentSaleProceedsVault.sol:L69-L100`](#)

Tests: [`AagentRedemptionV2.test.cjs:L240-L274`](#), [`AagentV2Integration.test.cjs:L98-L107`](#)

Purchase eligibility verifies schedule, phase, mode, limited-window state, and endpoint compatibility, but does not test projected reserve coverage before accepting consideration and increasing purchase receipts. Redemption correctly fails closed when the reserve is inadequate; this protects against overpayment but leaves an accepted purchase temporarily unrefundable. Sale proceeds remain locked in a separate vault and are not automatically available as USDT redemption reserves.

The underfunding test proves refund rejection when reserve coverage is insufficient. The integration test manually pre-funds the reserve before purchases, demonstrating that solvency currently depends on an operational step rather than a purchase-time invariant.

Impact: Valid purchases can create refund liabilities that cannot be serviced until an external reserve top-up. This is a financial-availability and assurance failure even though AGNT purchase claims remain recorded.

Required remediation: Enforce projected `reserveAfter >= requiredLiabilityAfter` during every purchase, or fully collateralize maximum refund liability before sales open. Test BNB, USDT, and USDC purchases under insufficient-reserve conditions and require atomic rejection.

MED-03 — Freshness-only oracle validation lacks bounds and deviation circuit breakers

Status: Open; no remediation retest

Code: ``AagentSwapV2.sol:L165-L167`, `AagentSwapV2.sol:L552-L618``

Test: ``AagentSwapV2.test.cjs:L424-L468``

The oracle adapter rejects nonpositive answers, missing or future timestamps, incomplete rounds, and observations older than one global maximum age. The allowed maximum can be as high as six hours. The implementation has no per-feed heartbeat, absolute price floor/ceiling, consecutive-round deviation check, secondary-source check, stablecoin depeg circuit breaker, or automatic pause.

Stablecoin prices are capped at one dollar on the upside, but a fast depeg within the allowed age may not be reflected in time. A technically fresh but anomalously high BNB answer can release excess AGNT up to inventory and sale caps.

Impact: Feed malfunction or fast market movement can create economically invalid quotes. User-supplied minimum output reduces some downside but does not replace protocol-side oracle anomaly controls.

Required remediation: Configure verified feed addresses and heartbeat per asset; enforce conservative bounds and deviation thresholds; use a stablecoin floor and pause behavior; optionally corroborate a secondary source. Add tests for extreme fresh answers, heartbeat mismatch, and sudden deviation.

LOW-01 — Fixed UTC daily buckets permit near-two-times throughput at a boundary

Status: Open; no remediation retest

Code: ``AagentRedemptionV2.sol:L713-L731``

Daily wallet and global counters use `block.timestamp / 1 days`. A participant can spend the full allowance immediately before midnight UTC and the next full allowance immediately after.

Impact: Almost twice the nominal daily throughput can occur in a short real-time interval. Entitlement and reserve checks bound the impact but do not preserve a rolling-day risk limit.

Required remediation: Use a rolling 24-hour window or token-bucket limiter. If UTC epochs are intentional, size controls for the two-epoch burst and document that semantics.

INFO-01 — Privileged controls do not enforce a multisig or general timelock

Status: Open; no remediation retest

Code: ``AagentMarketRegistry.sol:L96-L162`, `AagentSwapV2.sol:L339-L355`, `AagentRedemptionV2.sol:L426-L516``

Two-step ownership and a delayed post-launch rate reduce some risk. The code does not require a multisig or apply a general timelock to market-mode, window, inventory, and eligible reserve actions.

Required remediation: Assign owner roles to a documented multisig, separate emergency and treasury authority, timelock material nonemergency changes, and monitor all role/address changes before activation.

INFO-02 — Immutable recipients and narrow recovery paths create asset-liveness risk

Status: Open; no remediation retest

Code: [`AagentSaleProceedsVault.sol:L30-L93`](#), [`AagentSwapV2.sol:L671-L672`](#),
[`AagentRedemptionV2.sol:L895-L897`](#)

The immutable vault beneficiary must accept native BNB. A beneficiary contract that rejects BNB can block release. Vault token release is limited to USDT and USDC, while forced native currency and unrelated tokens have no general recovery path.

Required remediation: Test payable behavior and operational continuity of the beneficiary. Either explicitly accept irrecoverability or implement a constrained, timelocked recovery mechanism that cannot touch protected liabilities.

INFO-03 — Settlement events omit configuration evidence needed for complete reconstruction

Status: Open; no remediation retest

Code: [`AagentSwapV2.sol:L81-L90`](#), [`AagentRedemptionV2.sol:L122-L133`](#)

`PurchaseSettled` omits active mode and `configVersion`. `RedemptionSettled` includes mode and execution nonce but omits `configVersion`, `rateVersion`, and the cost-basis indicator.

Impact: An indexer cannot reconstruct every governing settlement parameter solely from event logs. Block-state calls can supplement evidence but are less durable and more operationally complex.

Required remediation: Emit the omitted fields or a versioned configuration digest, and add event-schema regression tests.

6. Verification matrix

Toolchain

Item	Version or setting
Node.js	v24.18.0
npm	11.16.0
Hardhat	2.29.0
ethers	6.17.0
Solidity compiler	0.8.24+commit.e11b9ed9

Item	Version or setting
Optimizer	enabled, 500 runs
EVM target	paris
OpenZeppelin Contracts	5.1.0
solidity-coverage	0.8.17
Slither	0.11.5
cryptic-compile	0.3.11

Dynamic tests

- Command: `npm.cmd test`
- Result: **42 passing, 0 failing**
- Included coverage of market scheduling/modes, limited windows, native/stable purchases, stale/depegged feeds, cost-basis refunds, claims, reserves, limits, rate delay, execution nonce/replay, integration, and deployment-script safety.
- Passing tests do not establish correctness for untested states or deployment configuration.

Coverage

Scope	Statements	Branches	Functions	Lines
All instrumented files	89.32% (301/337)	56.81% (242/426)	77.50% (62/80)	78.67% (472/600)
Four core contracts	89.67% (295/329)	56.40% (238/422)	85.07% (57/67)	79.72% (460/577)
Market Registry	92.45% (49/53)	65.00% (52/80)	100% (12/12)	90.22% (83/92)
Redemption V2	96.20% (152/158)	51.09% (94/184)	92.31% (24/26)	80.59% (220/273)
Sale Proceeds Vault	70.00% (14/20)	50.00% (16/32)	60.00% (3/5)	65.63% (21/32)
Swap V2	81.63% (80/98)	60.32% (76/126)	75.00% (18/24)	75.56% (136/180)

Coverage instrumentation expands branch counts and does not prove the absence of defects. Withdrawal failures, extreme oracle values, recovery behavior, and time-boundary bursts need additional targeted tests.

Static analysis

Slither completed successfully and produced **55 raw detector entries**:

Tool classification	Count
Medium	24

Tool classification	Count
Low	27
Informational	4

Detector	Count	Manual disposition
<code>incorrect-equality</code>	15	Intended zero, enum, sentinel, and exact-entitlement checks
<code>locked-ether</code>	1	Forced-native/recovery liveness captured in INFO-02
<code>uninitialized-local</code>	7	Solidity zero initialization with guarded assignments
<code>unused-return</code>	1	Ignored <code>startedAt</code> ; <code>updatedAt</code> and round ordering are checked
<code>missing-zero-check</code>	1	Mock-only result, outside production source scope
<code>reentrancy-events</code>	1	Fixed beneficiary/full-balance release; liveness remains, no repeatable withdrawal
<code>timestamp</code>	25	Intended schedules/deadlines; actionable boundary retained as LOW-01
<code>pragma</code>	1	Version convention, no separate security finding
<code>cyclomatic-complexity</code>	1	Maintainability/testability warning for redemption validation
<code>low-level-calls</code>	2	Restricted vault/beneficiary native-value flows

Raw static-analysis entries are heuristic. The accepted result remains 0 Critical, 0 High, 3 Medium, 1 Low, and 3 Informational.

7. Mainnet remediation gates

Gate	Required evidence	Current state
G-01	MED-01 cumulative/signed review control and negative tests	Open
G-02	MED-02 purchase-time collateral invariant for all payment assets	Open
G-03	MED-03 feed registry, heartbeat, bounds, deviation, pause tests	Open
G-04	LOW-01 rolling-window implementation or formally accepted burst model	Open

Gate	Required evidence	Current state
G-05	Multisig/timelock role plan and on-chain verification	Not assessed
G-06	Beneficiary payable test and explicit asset-recovery policy	Open
G-07	Versioned settlement evidence and indexer schema	Open
G-08	Final source freeze, repeat tests/coverage/Slither, line-by-line retest	Not performed
G-09	Deployed bytecode/source/constructor/address/role/oracle equality	Not supplied
G-10	Reserve funding, endpoint binding, pause state, and minimal-wallet acceptance receipts	Not supplied

8. Limitations

- This is a first-party review and not an independent certification.
- The assessment applies only to the listed SHA-256 snapshot. Any byte change requires comparison and, where material, retest.
- No deployed bytecode, constructor arguments, live roles, reserve balances, oracle registry, or transaction receipt was assessed.
- No fuzzing campaign, stateful invariant engine, symbolic execution, formal verification, economic simulation, or key-compromise exercise was performed.
- External token and oracle behavior was assumed from the supplied interfaces.
- Static-analysis classifications are heuristic and were manually triaged.
- The isolated coverage dependency tree is test-only and not part of production.

9. Conclusion

The reviewed snapshot has meaningful transaction-integrity and accounting controls, and the assessment did not identify a Critical or High-severity issue. The three Medium findings leave unresolved financial-availability, risk-policy, and pricing-integrity exposure.

Final disposition: remediation required before mainnet.